Universidad Nacional de Costa Rica

Escuela de Informática

Curso: Administración de Bases de Datos

II Ciclo 2026

Controles ISO/IEC 27001:2022 para la confidencialidad en la administración de bases de datos Oracle

Seguridad y auditoría de bases de datos

Estudiante:

Luis Felipe Jiménez Fernández

Profesor:

Johnny Villalobos Murillo

27 de octubre de 2026

1. Introducción

La confidencialidad es la propiedad de la información que impide su divulgación a personas, entidades o procesos no autorizados (ISO/IEC, 2026). En una base de datos, esa propiedad no depende de una sola herramienta, sino de lo que el Administrador de Bases de Datos (DBA) hace cada día: crear cuentas, otorgar privilegios, respaldar, auditar, parchear y clonar ambientes. Este informe diseña un marco de controles basado en ISO/IEC 27001:2022 (Anexo A) e ISO/IEC 27002:2022 para mitigar los riesgos de confidencialidad en esas tareas sobre Oracle Database 21c XE, y lo acompaña con una matriz de evaluación y pruebas observables y auditables mediante scripts SQL.

La metodología es el ciclo PHVA (Planificar-Hacer-Verificar-Actuar), la herramienta es Oracle SQL Developer y la documentación sigue APA 7. El informe presenta el marco teórico, los riesgos R-CONF, las tareas críticas del DBA, el mapeo de controles, los controles observables para un auditor externo, la matriz de evaluación, la batería de pruebas y la declaración del uso de inteligencia artificial.

2. Marco teórico

2.1 ISO/IEC 27001:2022 frente a la versión 2013

La edición 2022 de ISO/IEC 27001 mantiene los requisitos del sistema de gestión (cláusulas 4 a 10), pero su Anexo A se alinea con ISO/IEC 27002:2022: pasa de 114 controles en 14 dominios a 93 controles en 4 temas (organizacionales, de personas, físicos y tecnológicos) (ISO/IEC, 2022a, 2022b). Se agregan 11 controles nuevos, tres de ellos muy relevantes para un DBA: eliminación de información (8.10), enmascaramiento de datos (8.11) y prevención de fuga de datos (8.12). El enfoque por procesos de la cláusula 4.4 y la mejora continua, que se aplican aquí mediante PHVA, se mantienen.

2.2 Mínimo privilegio y separación de funciones en el rol DBA

El principio de mínimo privilegio establece que cada identidad reciba solo los permisos que su función requiere, y la separación de funciones evita que una sola persona controle un proceso completo (control 5.3). Oracle recomienda otorgar privilegios solo a quien los necesita, asignarlos mediante roles, restringir los privilegios *ANY* y no conceder *SYSDBA* a quien no sea administrador (Oracle, 2024c). Un DBA con el rol *DBA* para tareas cotidianas viola ambos

principios: por eso se recomiendan cuentas nominales de trabajo, una cuenta privilegiada separada para actividades administrativas y roles específicos como *SYSBACKUP* o *SYSKM* para respaldos y llaves.

2.3 Defensa en profundidad y Zero Trust

La defensa en profundidad superpone capas: red (listener, cifrado de tráfico), autenticación, autorización, cifrado de datos, auditoría y respaldo, de modo que el fallo de una capa no exponga los datos. Zero Trust parte de que ninguna conexión es confiable por su ubicación y exige autenticar y autorizar cada acceso, con privilegios mínimos y monitoreo continuo (Rose et al., 2020). Aplicado a bases de datos, significa no confiar en que "viene de la red interna", verificar cada sesión y registrar los accesos a los datos sensibles.

2.4 Controles técnicos en Oracle

Transparent Data Encryption (TDE) cifra columnas o tablespaces en reposo y depende de un almacén de llaves; protege frente al robo de archivos de datos o respaldos (Oracle, 2024a). **Enmascaramiento:** el término "Dynamic Data Masking" se asocia a otros motores; en Oracle el equivalente dinámico es **Data Redaction**, que oculta valores al devolver resultados según la política, mientras que Data Masking and Subsetting ofusca datos de forma estática para clonar ambientes. Estas opciones dependen de la edición y las licencias, por lo que en XE se complementan con vistas de enmascaramiento (Oracle, 2024a). **Row Level Security / VPD** restringe filas visibles mediante políticas (*DBMS_RLS*). **TLS** y el cifrado nativo de Oracle Net protegen el tráfico entre cliente y servidor.

2.5 DLP, respaldos cifrados, logging y SIEM

La prevención de fuga de datos (control 8.12) en Oracle implica restringir paquetes que sacan datos del servidor (*UTL_FILE*, *UTL_HTTP*, *UTL_SMTP*), controlar objetos *DIRECTORY* y los roles de exportación de Data Pump. Los respaldos deben cifrarse y custodiarse (8.13); RMAN soporta respaldos cifrados (Oracle, 2024b). El registro y monitoreo (8.15, 8.16) se apoya en la auditoría unificada, cuya pista reside en el esquema *AUDSYS* y se consulta mediante *UNIFIED_AUDIT_TRAIL* (Oracle, 2024c); estos registros pueden enviarse a un SIEM para correlacionar eventos, por ejemplo mediante el syslog del sistema operativo según plataforma y versión.

2.6 Normativa costarricense

La Ley 8968 obliga al responsable de una base de datos a adoptar medidas técnicas y organizativas de seguridad, incluidas las físicas y lógicas (artículo 10), y establece el deber de confidencialidad de quienes intervienen en el tratamiento, aun terminada su relación (artículo 11) (Asamblea Legislativa de Costa Rica, 2011). Su reglamento, el Decreto Ejecutivo 37554-JP, desarrolla las medidas de seguridad administrativas, físicas y lógicas (artículo 34), exige análisis de riesgos (artículo 36) y regula la notificación de vulneraciones (artículos 38 y 39) (Poder Ejecutivo de Costa Rica, 2013).

3. Riesgos de confidencialidad R-CONF

Impacto (I) y probabilidad (P) se califican de 1 a 5; el nivel resulta del producto: 1 a 6 bajo, 7 a 14 medio y 15 a 25 alto (ISO/IEC, 2022c). Los valores son una propuesta inicial para validar con el contexto del entorno evaluado.

Tabla 1

Riesgos de confidencialidad en bases de datos Oracle

ID	Riesgo	Amenaza y vulnerabilidad	I	P	I×P	Nivel
R-CONF-01	Acceso no autorizado a datos por exceso o herencia de privilegios	Usuario interno o cuenta comprometida; privilegios *ANY*, roles anidados, *PUBLIC*	5	4	20	Alto
R-CONF-02	Suplantación por credenciales débiles, por defecto o compartidas	Ataque de fuerza bruta o reutilización; contraseñas por defecto, perfiles laxos	5	3	15	Alto
R-CONF-03	Fuga por respaldos, archivos de datos o redo archivados sin cifrar	Robo o copia de medios; falta de TDE y de cifrado de RMAN	5	3	15	Alto
R-CONF-04	Exposición de datos reales en clones DEV/TEST	Copia de producción a ambientes menos protegidos; datos sin enmascarar	4	4	16	Alto
R-CONF-05	Acceso sin detección por auditoría y logs ausentes o manipulables	Abuso de privilegios sin rastro; sin políticas de auditoría ni monitoreo	4	4	16	Alto
R-CONF-06	Intercepción de tráfico o exposición del listener	Escucha de red; tráfico en claro, listener sin restricción de origen	4	3	12	Medio

Nota. Elaboración propia a partir de ISO/IEC (2022c) y Oracle (2024c).

4. Tareas críticas del DBA

Tabla 2

Tareas críticas del DBA, riesgos y controles asociados

ID	Tarea	Objetos o comandos Oracle	Riesgo	Controles Anexo A
T-01	Creación y baja de usuarios	*CREATE USER*, *DROP USER*, *DBA_USERS*	R-CONF-01, 02	A5.16, A5.18
T-02	Asignación de privilegios y roles	*GRANT*, *REVOKE*, *DBA_SYS_PRIVS*, *DBA_ROLE_PRIVS*	R-CONF-01	A5.15, A5.18, A8.2, A8.3
T-03	Gestión de cuentas privilegiadas	*SYS*, *SYSTEM*, *SYSDBA*, *V$PWFILE_USERS*	R-CONF-01, 02	A8.2, A8.5
T-04	Autenticación y perfiles de contraseña	*CREATE PROFILE*, *DBA_PROFILES*	R-CONF-02	A5.17, A8.5
T-05	Clasificación de datos sensibles	*COMMENT ON COLUMN*, *DBA_COL_COMMENTS*	R-CONF-01, 04	A5.12
T-06	Cifrado en reposo (TDE)	*V$ENCRYPTION_WALLET*, *DBA_ENCRYPTED_COLUMNS*	R-CONF-03	A8.24 (adicional)
T-07	Enmascaramiento y redacción de datos	Vistas de masking, *DBMS_REDACT*	R-CONF-04	A8.11, A5.12
T-08	Respaldos RMAN cifrados	*RMAN*, *V$RMAN_BACKUP_JOB_DETAILS*	R-CONF-03	A8.13, A5.33
T-09	Auditoría unificada	*CREATE AUDIT POLICY*, *UNIFIED_AUDIT_TRAIL*	R-CONF-05	A8.15, A5.33
T-10	Gestión de logs y redo	Alert log, redo, *LogMiner*, *V$DIAG_INFO*	R-CONF-03, 05	A8.15, A5.33
T-11	Parcheo	*DBA_REGISTRY_SQLPATCH*, *V$VERSION*	R-CONF-01, 06	A8.8 (adicional)
T-12	Configuración del listener y la red	*LSNRCTL*, *sqlnet.ora*, *V$SESSION_CONNECT_INFO*	R-CONF-06	A8.20
T-13	Eliminación segura de información	*PURGE*, *DBA_RECYCLEBIN*, retiro de datafiles	R-CONF-03	A8.10
T-14	Clones DEV/TEST	Data Pump, *DBA_DIRECTORIES*, masking	R-CONF-04	A8.11, A8.12

Nota. Elaboración propia. Los controles A8.24 y A8.8 no están en la lista de la asignación y se incluyen como complemento justificado (ISO/IEC, 2022b).

5. Mapeo de controles ISO con implementación y evidencia observable

Tabla 3

Controles del Anexo A 2022, implementación sugerida en Oracle y evidencia observable

Control	Nombre (ISO/IEC 27002:2022)	Implementación sugerida en Oracle	Evidencia observable
A5.12	Classification of information	Etiquetar columnas con clasificación mediante comentarios y mantener un inventario de datos sensibles	*SELECT ... FROM DBA_COL_COMMENTS WHERE COMMENTS LIKE 'CLASIF=%'*

Control	Nombre (ISO/IEC 27002:2022)	Implementación sugerida en Oracle	Evidencia observable
A5.15	Access control	Política de acceso por roles de trabajo; sin privilegios directos a usuarios	*DBA_ROLE_PRIVS*, *DBA_TAB_PRIVS*
A5.16	Identity management	Cuentas nominales y únicas; sin cuentas compartidas; alta y baja con solicitud aprobada	*DBA_USERS* (username, created, account_status)
A5.17	Authentication information	Perfiles con función de verificación, bloqueo por intentos fallidos y expiración	*DBA_PROFILES*, *DBA_USERS_WITH_DEFPWD*
A5.18	Access rights	Revisión periódica de derechos; bloqueo de cuentas sin uso	*DBA_USERS.LAST_LOGIN*, *DBA_ROLE_PRIVS*
A5.33	Protection of records	Proteger la pista de auditoría y los redo archivados; definir retención	*DBA_AUDIT_MGMT_CONFIG_PARAMS*, *V$ARCHIVED_LOG*
A8.2	Privileged access rights	Limitar *DBA*, *SYSDBA* y privilegios *ANY*; cuenta privilegiada separada	*V$PWFILE_USERS*, *DBA_SYS_PRIVS*
A8.3	Information access restriction	Acceso a datos solo por vistas y roles; VPD donde la edición lo permita	*DBA_TAB_PRIVS*, *DBA_POLICIES*
A8.5	Secure authentication	Límite de intentos fallidos, archivo de contraseñas exclusivo, autenticación robusta	*V$PARAMETER*, *DBA_PROFILES*
A8.10	Information deletion	Purgar papelera, retirar datafiles y respaldos vencidos con borrado seguro	*DBA_RECYCLEBIN*, parámetro *recyclebin*
A8.11	Data masking	Vistas de masking y Data Redaction (según edición); masking estático para clones	Vista *V_CLIENTES_MASK*, *REDACTION_POLICIES*
A8.12	Data leakage prevention	Revocar a *PUBLIC* los paquetes *UTL_FILE, UTL_HTTP, UTL_SMTP*; controlar *DIRECTORY* y Data Pump	*DBA_TAB_PRIVS*, *DBA_DIRECTORIES*
A8.13	Information backup	Respaldos RMAN cifrados, en ARCHIVELOG, con custodia y prueba de restauración	*SHOW ALL* (RMAN), *V$RMAN_BACKUP_JOB_DETAILS*
A8.15	Logging	Auditoría unificada sobre objetos sensibles y acciones privilegiadas	*UNIFIED_AUDIT_TRAIL*, *AUDIT_UNIFIED_ENABLED_POLICIES*
A8.20	Networks security	Cifrado de red (TLS o cifrado nativo), restricción de origen en el listener	*V$SESSION_CONNECT_INFO*, *lsnrctl status*, *sqlnet.ora*

Nota. Nombres de controles según ISO/IEC (2022b). Implementaciones basadas en Oracle (2024c, 2024a, 2024b).

6. Controles observables para un auditor externo

Cada control observable puede ejecutarse sin modificar la base de datos y deja evidencia fechada. El script indicado se encuentra en el repositorio.

Tabla 4

Quince controles observables

ID	Qué se verifica	Consulta o comando	Control	Script
OBS-01	Privilegios *ANY* en cuentas de usuario	*DBA_SYS_PRIVS* con *oracle_maintained = 'N'*	A8.2	01
OBS-02	Usuarios con el rol *DBA*	*DBA_ROLE_PRIVS* con *granted_role = 'DBA'*	A8.2	01
OBS-03	Roles con *ADMIN OPTION* o heredados	*DBA_ROLE_PRIVS*	A5.18	01

ID	Qué se verifica	Consulta o comando	Control	Script
OBS-04	Cuentas con *SYSDBA*, *SYSOPER*, *SYSBACKUP*	*V$PWFILE_USERS*	A8.2	01
OBS-05	*PUBLIC* con *EXECUTE* sobre *UTL_FILE, UTL_HTTP, UTL_SMTP*	*DBA_TAB_PRIVS*	A8.12	01
OBS-06	Directorios y roles de exportación	*DBA_DIRECTORIES*, roles de Data Pump	A8.12	01
OBS-07	Cuentas con contraseña por defecto	*DBA_USERS_WITH_DEFPWD*	A5.17	02
OBS-08	Política de contraseñas por perfil	*DBA_PROFILES*	A5.17, A8.5	02
OBS-09	Cuentas abiertas sin uso en 120 días	*DBA_USERS.LAST_LOGIN*	A5.18	02
OBS-10	Estado del almacén de llaves TDE	*V$ENCRYPTION_WALLET*	A8.24	03
OBS-11	Cifrado de red en sesiones	*V$SESSION_CONNECT_INFO*	A8.20	03
OBS-12	Columnas clasificadas	*DBA_COL_COMMENTS*	A5.12	04
OBS-13	Privilegios efectivos del rol de consulta enmascarada	*DBA_TAB_PRIVS*, *DBA_ROLE_PRIVS*	A8.11, A8.3	04
OBS-14	Auditoría unificada habilitada y políticas activas	*V$OPTION*, *AUDIT_UNIFIED_ENABLED_POLICIES*	A8.15	05a, 05b
OBS-15	Registros de acceso a objetos confidenciales	*UNIFIED_AUDIT_TRAIL*	A8.15, A5.33	05a, 05b

Nota. Elaboración propia. Los scripts 03 a 06 también incluyen evidencia de respaldos, logs, parches y eliminación segura.

7. Matriz de evaluación

El criterio de madurez usa la escala de la Tabla 5. El estado se deriva del criterio: 4 es Cumple, 2 y 3 son Parcial, 0 y 1 son No cumple. Las filas marcadas con (S) coinciden con la salida de *08_matriz_evaluacion.sql*; las demás se evaluaron manualmente con la escala de la Tabla 5 y la evidencia indicada.

Tabla 5

Escala de madurez 0 a 4

Nivel	Denominación	Descripción
0	Inexistente	El control no existe o no se aplica
1	Inicial	Se aplica de forma ocasional y sin documentar
2	Repetible	Se aplica con regularidad pero con excepciones o sin evidencia completa
3	Definido	Procedimiento documentado y aplicado, con evidencia, pendiente de medición
4	Gestionado	Aplicado, medido, revisado periódicamente y con evidencia auditable

Tabla 6

Matriz de evaluación de controles de confidencialidad

Tarea	Riesgo	Control	Criterio 0-4	Evidencia y resultado	Estado
T-01	R-CONF-01	A5.18	2	PDBADMIN abierta sin ingreso registrado en 120 días (OBS-09) (S)	Parcial

Tarea	Riesgo	Control	Criterio 0-4	Evidencia y resultado	Estado
T-02	R-CONF-01	A8.2	4	0 cuentas con privilegios ANY (OBS-01) (S)	Cumple
T-03	R-CONF-01	A8.2	4	0 cuentas con rol DBA (OBS-02); PDBADMIN con PDB_DBA y ADMIN OPTION (OBS-03) (S)	Cumple
T-04	R-CONF-02	A5.17	4	0 cuentas con contraseña por defecto (OBS-07) (S)	Cumple
T-04	R-CONF-02	A8.5	2	FAILED_LOGIN_ATTEMPTS del perfil DEFAULT = 10; CIS pide 5 o menos (OBS-08) (S)	Parcial
T-04	R-CONF-02	A5.17	0	Verificación de contraseña NULL (0); vida 180 (2); bloqueo 1 (4) (OBS-08) (S)	No cumple
T-05	R-CONF-04	A5.12	2	Columnas clasificadas solo en el esquema demo, sin inventario formal (OBS-12)	Parcial
T-06	R-CONF-03	A8.24	0	Wallet NOT_AVAILABLE; sin columnas ni tablespaces cifrados (OBS-10) (S)	No cumple
T-07	R-CONF-04	A8.11	3	Vista de masking efectiva (PT-04, PT-05); sin Data Redaction; solo en el demo (OBS-13)	Parcial
T-08	R-CONF-03	A8.13	2	ARCHIVELOG; 29 conjuntos del 05/10/26; cifrado de RMAN en OFF (06b) (S)	Parcial
T-09	R-CONF-05	A8.15	4	Línea base 2 políticas; tras implementar, 4 (OBS-14, OBS-15) (S)	Cumple
T-10	R-CONF-05	A5.33	2	Pista en SYSAUX sin retención ni purga definidas (05b)	Parcial
T-11	R-CONF-01	A8.8	1	Sin parches en DBA_REGISTRY_SQLPATCH; versión 21.3 XE (06) (S)	No cumple
T-12	R-CONF-06	A8.20	1	Sin cifrado de red; listener sin restricción de nodos (OBS-11, 03b a 03e) (S)	No cumple
T-13	R-CONF-03	A8.10	2	Papelera activa y vacía; sin procedimiento de borrado seguro (06)	Parcial
T-14	R-CONF-04	A8.12	1	PUBLIC con EXECUTE en UTL_TCP, UTL_HTTP, UTL_FILE, UTL_SMTP (OBS-05) (S)	No cumple

Nota. Resultados de la ejecución del 22 de octubre de 2026 en Oracle Database 21c XE; las evidencias (.log) están en la carpeta evidencias del repositorio. En T-09 la línea base fue de 2 políticas y el valor 4 incluye las dos políticas creadas en la demostración.

Tabla 7

Umbrales del criterio 4 y su referencia

Verificación	Valor que otorga criterio 4 (script 08)	Fuente	Tipo
FAILED_LOGIN_ATTEMPTS del perfil *DEFAULT*	5 o menos (6 a 10: criterio 2; *UNLIMITED*: 0)	CIS, rec. 3.1 (el STIG exige 3 o menos, V-270550)	Referencia externa
PASSWORD_LIFE_TIME	90 días o menos	CIS, rec. 3.3	Referencia externa
PASSWORD_LOCK_TIME	1 o mayor	CIS, rec. 3.2	Referencia externa
PASSWORD_VERIFY_FUNCTION	Asignada (distinta de *NULL*)	CIS, rec. 3.7	Referencia externa
INACTIVE_ACCOUNT_TIME	120 días o menos	CIS, rec. 3.9	Referencia externa

Verificación	Valor que otorga criterio 4 (script 08)	Fuente	Tipo
Contraseñas por defecto	Ninguna cuenta	CIS, rec. 4.1	Referencia externa
Privilegios *ANY* en cuentas de usuario	0 (1 a 2: 3; 3 a 5: 2; más: 0)	Mínimo privilegio (Oracle, 2024c)	Criterio del autor
Cuentas con rol *DBA*	0 (1: 3; 2: 2; más: 0)	Mínimo privilegio (Oracle, 2024c)	Criterio del autor
PUBLIC con *EXECUTE* en *UTL_FILE, UTL_HTTP, UTL_TCP, UTL_SMTP*	Ninguno	Oracle (2024c); CIS, sec. 5.1.1 (paquetes de red y sistema de archivos)	Criterio del autor
Almacén de llaves TDE, auditoría, respaldo, cifrado de red, parches	Abierto; 3 o más políticas; ARCHIVELOG y respaldo en 7 días; sesión cifrada; parche en 365 días	ISO/IEC (2022b), controles 8.24, 8.15, 8.13, 8.20 y 8.8	Criterio del autor

Nota. CIS = Center for Internet Security (2022), versión para Oracle 19c, usada como referencia análoga para 21c XE. Estado: 4 es Cumple, 2 y 3 Parcial, 0 y 1 No cumple.

8. Batería de pruebas técnicas

Tabla 8

Batería de pruebas

ID	Tipo	Procedimiento	Resultado esperado	Herramienta	Resultado obtenido
PT-01	Consulta	Ejecutar OBS-01 y OBS-02 y comparar con la matriz de roles aprobada	Sin cuentas de usuario con privilegios *ANY* ni rol *DBA* no justificados	Script 01	Cumple: 0 cuentas con *ANY* ni *DBA*
PT-02	Consulta	Ejecutar OBS-05 sobre *PUBLIC* y *UTL_FILE, UTL_HTTP, UTL_TCP, UTL_SMTP*	Sin *EXECUTE* para *PUBLIC*; de lo contrario, hallazgo	Script 01	Hallazgo: *PUBLIC* con *EXECUTE* en los cuatro, más *UTL_INADDR* y *DBMS_LDAP*
PT-03	Consulta	Ejecutar OBS-07 y OBS-08	Cero cuentas con contraseña por defecto; perfiles con intentos fallidos limitados	Script 02	Cumple en cuentas (0); hallazgo en el perfil *DEFAULT*: 10 intentos y sin función de verificación
PT-04	Funcional negativa	Con *CONF_ANALISTA* ejecutar una consulta directa a *conf_demo.clientes*	Error ORA-00942: sin acceso a la tabla base	SQL Developer, script 05c	Cumple: ORA-00942
PT-05	Funcional	Con *CONF_ANALISTA* consultar *conf_demo.v_clientes_mask*	Cédula y tarjeta enmascaradas	SQL Developer, script 05c	Cumple: 3 filas con valores enmascarados
PT-06	Auditoría	Tras PT-04 y PT-05, consultar *UNIFIED_AUDIT_TRAIL*	Registros de ambos accesos con usuario, acción y código de retorno	Script 05b	Cumple: acceso a la vista (código 0) y 2 intentos fallidos a la tabla (código 2004)
PT-07	Auditoría	Crear y eliminar un usuario de prueba con *pol_conf_privilegiados* activa	Eventos *CREATE USER* y *DROP USER* en la pista	Script 05d	Cumple: *CREATE USER*, *GRANT* y *DROP USER* registrados
PT-08	Configuración	Consultar *V$ENCRYPTION_WALLET*	Estado *OPEN* si la edición soporta TDE; si no, hallazgo documentado	Script 03	Hallazgo: *NOT_AVAILABLE*; TDE no configurado

ID	Tipo	Procedimiento	Resultado esperado	Herramienta	Resultado obtenido
PT-09	Configuración	Ejecutar *SHOW ALL* y *LIST BACKUP SUMMARY* en RMAN	Cifrado configurado y respaldo reciente	RMAN, 06b	Parcial: cifrado en *OFF*; 29 conjuntos del 05/10/26
PT-10	Configuración	Consultar *LOGMINING* y *EXECUTE_CATALOG_ROLE*	Solo cuentas administrativas autorizadas	Script 06	Cumple: solo *SYS*, *DBA* y roles de fábrica
PT-11	Red	Revisar *lsnrctl status*, *sqlnet.ora* y los servicios de red de la sesión	Listener restringido y cifrado de red observado	CMD, script 03	Hallazgo: TCP 1521 sin restricción de nodos; sin cifrado; sin adaptador de cifrado activo
PT-12	Evaluación	Ejecutar *08_matriz_evaluacion.sql*	Criterios y estados coherentes con la evidencia de las demás pruebas	Script 08	Ejecutado: 15 criterios; 5 Cumple, 5 Parcial, 5 No cumple

Nota. Elaboración propia. Resultados del 22/10/2026. Las lecturas (01, 02, 03, 06, 08) se ejecutan con el usuario auditor creado en el script 00; los scripts 00, 04, 05a, 05b y 07 requieren SYS en el PDB (XEPDB1). El 07 elimina los esquemas de demostración.

9. Resultados y hallazgos

El 22 de octubre de 2026 se ejecutaron los scripts sobre Oracle Database 21c Express Edition (versión 21.3.0.0.0), en el PDB *XEPDB1*; los registros de cada ejecución se conservan en la carpeta evidencias del repositorio. De los 15 criterios que calcula el script 08, cinco resultaron Cumple, cinco Parcial y cinco No cumple. Los controles de acceso por privilegios quedaron bien (sin privilegios *ANY* ni cuentas con el rol *DBA*), mientras que los controles de cifrado, red, perfiles de contraseña y paquetes expuestos a *PUBLIC* concentran los hallazgos.

En el ciclo PHVA, la fase Hacer dejó un resultado medible en auditoría: la línea base eran 2 políticas habilitadas de fábrica, y tras crear las políticas de accesos a objetos confidenciales y de acciones privilegiadas pasaron a 4. Además, la demostración con *CONF_ANALISTA* mostró que el mínimo privilegio y el masking funcionan: el analista vio los datos enmascarados y fue rechazado en la tabla base, con ambos intentos registrados en la pista de auditoría.

Tabla 9

Hallazgos y acciones correctivas (fase Actuar)

ID	Hallazgo	Riesgo	Acción correctiva sugerida	Prioridad
H-01	*PUBLIC* con *EXECUTE* en *UTL_TCP*, *UTL_HTTP*, *UTL_FILE* y *UTL_SMTP*	R-CONF-01	Revocar a *PUBLIC* y conceder solo a roles o cuentas que lo requieran, verificando dependencias y las ACL de red	Alta
H-02	Perfil *DEFAULT* laxo: 10 intentos, vida 180 días, inactividad 365 y sin función de verificación	R-CONF-02	Asignar *ORA_CIS_PROFILE* a los usuarios y ajustar *DEFAULT* a los valores del CIS	Alta

ID	Hallazgo	Riesgo	Acción correctiva sugerida	Prioridad
H-03	Sin TDE: wallet no disponible y sin objetos cifrados	R-CONF-03	Configurar el almacén de llaves y cifrar los tablespaces sensibles si la edición lo permite; de lo contrario, documentar un control compensatorio	Alta
H-04	Respaldos sin cifrar y sin respaldo reciente (último, 05/10/2026)	R-CONF-03	Activar el cifrado de respaldos si está disponible, custodiar el destino y programar respaldos dentro de la ventana de retención	Alta
H-05	Sin cifrado de red ni restricción de nodos en el listener	R-CONF-06	Configurar cifrado en *sqlnet.ora* o TLS, y restringir orígenes con *TCP.VALIDNODE_CHECKING*	Media
H-06	Pista de auditoría en *SYSAUX* sin retención ni purga definidas	R-CONF-05	Definir retención y purga con *DBMS_AUDIT_MGMT* y enviar los registros a un SIEM	Media
H-07	*PDBADMIN* abierta sin ingreso registrado	R-CONF-01	Evaluar y bloquear la cuenta si no se requiere	Media
H-08	Sin parches registrados (edición XE)	R-CONF-01, 06	Seguir las nuevas versiones del producto y documentar la limitación	Baja

Nota. Elaboración propia a partir de la ejecución del 22/10/2026 y de CIS (2022).

Limitaciones: la referencia CIS corresponde a Oracle 19c y se usó de forma análoga para 21c XE; las evidencias de respaldos provienen de RMAN a nivel del CDB, porque desde el PDB las vistas de respaldo pueden verse vacías; y las filas T-05, T-07, T-10 y T-13 se calificaron manualmente. Durante la ejecución se corrigieron dos errores de los propios scripts (un intervalo mal definido y una detección de cifrado de red que daba un falso positivo), lo que refleja la fase Actuar del ciclo.

Herramienta complementaria: el repositorio incluye un panel web (Python y FastAPI, carpeta panel/) que muestra riesgos, tareas, controles, matriz y pruebas, y que tiene tres modos: evidencias guardadas, consulta en vivo con el usuario conf_auditor, y un Lab que ejecuta los scripts como SYS con lista cerrada de scripts y confirmación escrita. Se usó para repetir las verificaciones con la base real; su uso de IA se declara en la Tabla 10.

10. Uso ético y documentado de inteligencia artificial

Tabla 10

Registro de uso de IA generativa

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / corrección del estudiante	Fuente verificada
Claude (Anthropic)	"Generar algo así como una especie de ensayo donde me ligue el riesgo de confidencialidad de la información desde el punto de vista de las normas ISO basado en procesos. Procesos que tienen que ver con la administración de bases de datos utilizando el servidor Oracle." Con formato universitario, portada, referencias reales.	Primer ensayo con marco ISO por procesos, matriz de riesgo y consultas Oracle de ejemplo	El borrador inicial generado con IA se convirtió en informe final tras ejecutar los scripts en Oracle 21c XE: completé la matriz con criterios y estados reales, agregué la sección de resultados y hallazgos con la evidencia obtenida y corregí los scripts que fallaron. Con apoyo de Claude, contrasté los nombres de los controles con el listado publicado del Anexo A.	ISO/IEC 27001, 27002 y 27005:2022 (iso.org); Oracle Database Security Guide 21c
Claude (Anthropic)	"Especificaciones del profesor:" con el PDF de la asignación adjunto	Informe alineado a la rúbrica: tablas R-CONF, tareas, mapeo A5/A8, controles observables, matriz, pruebas y scripts SQL 01 a 08	Ejecuté los scripts 00 a 08 en Oracle 21c XE y conservé los .log en evidencias/. Corregí errores de los propios scripts (intervalo mal definido, falso positivo en la detección de cifrado de red, ajuste del A8.13 en los scripts 06 y 08, y re-ejecución de 00b y 02). Con apoyo de Claude, contrasté los 15 controles de la asignación y los dos adicionales (A8.8, A8.24) con el listado publicado: los nombres coinciden.	Nombres de controles ISO/IEC 27002:2022; Decreto 37554-JP; NIST SP 800-207; Oracle 21c
Claude (Anthropic)	Prompt original no conservado (sesión del 16/10/2026). Solicitud reconstruida: mejorar los scripts para usar un usuario auditor de solo lectura, generar SPOOL y calcular la matriz con umbrales basados en CIS y STIG.	Scripts v2 (usuario auditor, SPOOL), matriz base por completar, umbrales anclados a CIS y STIG	Con apoyo de Claude, verifiqué en la página de DISA STIG que la regla V-270550 exige FAILED_LOGIN_ATTEMPTS de 3 o menos. El benchmark CIS 19c no pude consultarlo directamente (requiere registro), por lo que sus umbrales son una referencia no verificada de forma independiente.	CIS Oracle Database 19c Benchmark v1.1.0; DISA STIG Oracle 19c V-270550
Claude (Anthropic)	"Hazlo con Python y FastAPI, tengo experiencia en Python pero no con FastAPI." y "la idea es tocar la base con credenciales SYS a través de la web." (sesión del 23/10/2026)	Panel web (FastAPI) con modos de evidencias, en vivo y Lab de ejecución de scripts, y su rediseño de interfaz	Ejecuté el panel contra mi Oracle 21c XE (modo en vivo y Lab) y comparé sus resultados con los del informe; la diferencia en T-09 se explica porque el script 07 elimina las políticas de demostración. Corrieron las 37 pruebas automáticas del panel.	Salidas propias en evidencias/panel/; documentación del panel en panel/README.md

Nota. El prompt de la fila 3 se reconstruyó a partir del aporte, porque el original no se conservó. El estudiante verificó cada fila con la evidencia indicada.

Declaración jurada

Yo, Luis Felipe Jiménez Fernández, declaro que todo contenido generado con IA ha sido declarado en la tabla anterior, validado contra fuentes oficiales (ISO, documentación del motor de base de datos) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

Firma:  Fecha: 27/10/2026

11. Conclusiones

La confidencialidad en Oracle se gestiona como un conjunto de procesos del DBA, cada uno con su riesgo, su control y su evidencia. Los riesgos más altos del marco propuesto, el exceso de privilegios, los respaldos sin cifrar, los clones sin enmascarar y la falta de auditoría, corresponden a tareas rutinarias y no a escenarios exóticos, y por eso el ciclo PHVA con revisión periódica es la herramienta de gestión más importante.

En la ejecución sobre Oracle 21c XE, de los 15 criterios evaluados automáticamente cinco resultaron Cumple, cinco Parcial y cinco No cumple. Los privilegios y la auditoría respondieron bien tras aplicar los controles, mientras que el cifrado en reposo, el cifrado de red, los respaldos, los perfiles de contraseña y los paquetes expuestos a *PUBLIC* quedaron como hallazgos prioritarios.

La distinción entre control sugerido y evidencia observable permite que un auditor externo repita las verificaciones con las propias vistas de Oracle. Los scripts y la matriz convierten el marco en algo ejecutable: el estado de cada control surge del diccionario de datos y no de la opinión del evaluador. Quedan como limitaciones que varias opciones de seguridad (TDE, Data Redaction, VPD) dependen de la edición, y que los valores de impacto y probabilidad deben calibrarse en cada organización.

Referencias

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley n.° 8968: Protección de la persona frente al tratamiento de sus datos personales*. 7 de julio de 2011.

Center for Internet Security. (2022). *CIS Oracle Database 19c benchmark* (v1.1.0). CIS.

Defense Information Systems Agency. (2026). *Oracle Database 19c security technical implementation guide* (regla V-270550). https://www.stigviewer.com/stigs/oracle_database_19c/2026-02-25/finding/V-270550

International Organization for Standardization & International Electrotechnical Commission. (2022a). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (3.ª ed.). ISO/IEC.

International Organization for Standardization & International Electrotechnical Commission. (2022b). *ISO/IEC 27002:2022. Information security, cybersecurity and privacy protection — Information security controls* (3.ª ed.). ISO/IEC.

International Organization for Standardization & International Electrotechnical Commission. (2022c). *ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks* (4.ª ed.). ISO/IEC.

International Organization for Standardization & International Electrotechnical Commission. (2026). *ISO/IEC 27000:2026. Information security, cybersecurity and privacy protection — Information security management systems — Overview* (6.ª ed.). ISO/IEC.

Oracle. (2024a). *Oracle Database advanced security guide, 21c* (F31829-15). https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/

Oracle. (2024b). *Oracle Database backup and recovery user's guide, 21c* (F31836-11). https://docs.oracle.com/en/database/oracle/oracle-database/21/bradv/

Oracle. (2024c). *Oracle Database security guide, 21c* (F31285-18). https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/

Poder Ejecutivo de Costa Rica. (2013). *Decreto Ejecutivo n.° 37554-JP: Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales* (30 de octubre de 2012). La Gaceta n.° 45, Alcance Digital n.° 42, 5 de marzo de 2013.

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207